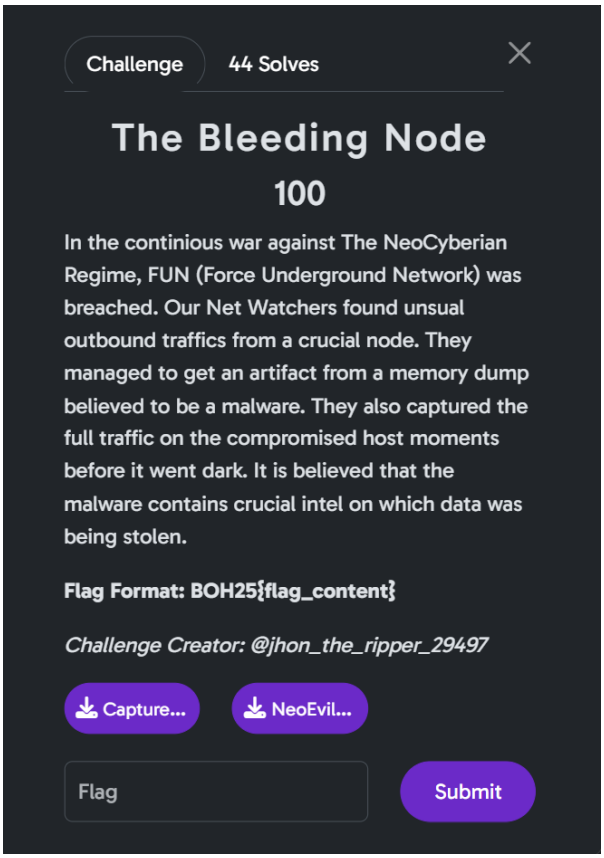
Bleeding Note



Main Task

Recover the stolen data from the pcap file.

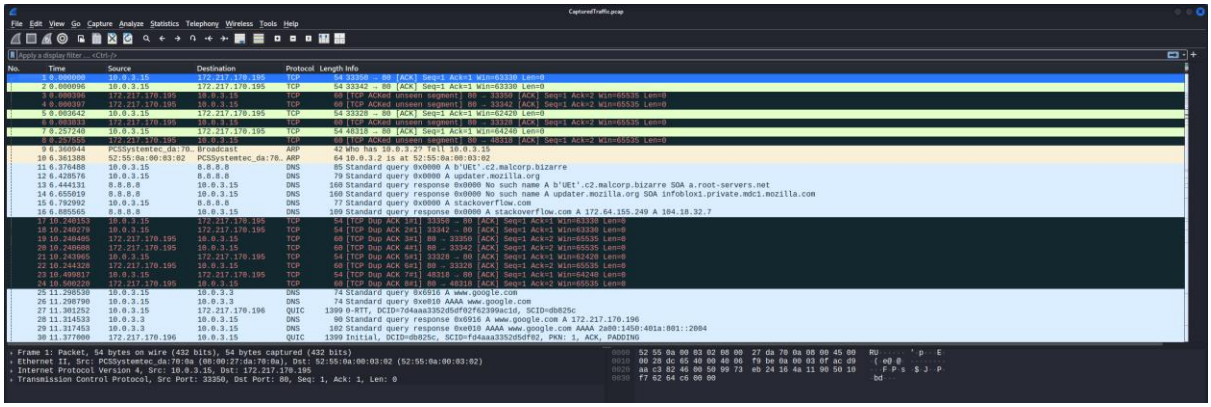
```
┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ ls
CapturedTraffic.pcap  NeoEvilBeacon

┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ file CapturedTraffic.pcap
CapturedTraffic.pcap: pcap capture file, microsecond ts (little-endian) - version 2.4 (Ethernet, capture length 262144)

┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ file NeoEvilBeacon
NeoEvilBeacon: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), statically linked, no section header
```

There are two files provided, which is CapturedTraffic.pcap and NeoEvilBeacon.

```
┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ ./NeoEvilBeacon
Initializing C2 connection...
Target Domain: c2.malcorp.bizarre
Exfil Protocol: DNS-QUERY
Data Encoding Algorithm: Vigenère Encode → Base64 Encode
Key: owned
Beaconing complete.
```

I first executed the NeoEvilBeacon and it gave me some important clues.

1. C2 Domain: c2.malcorp.bizarre
2. Protocol: DNS-QUERY
3. Encoding Algorithm: Vigenère Encode -> Base64 Encode
4. Key: owned

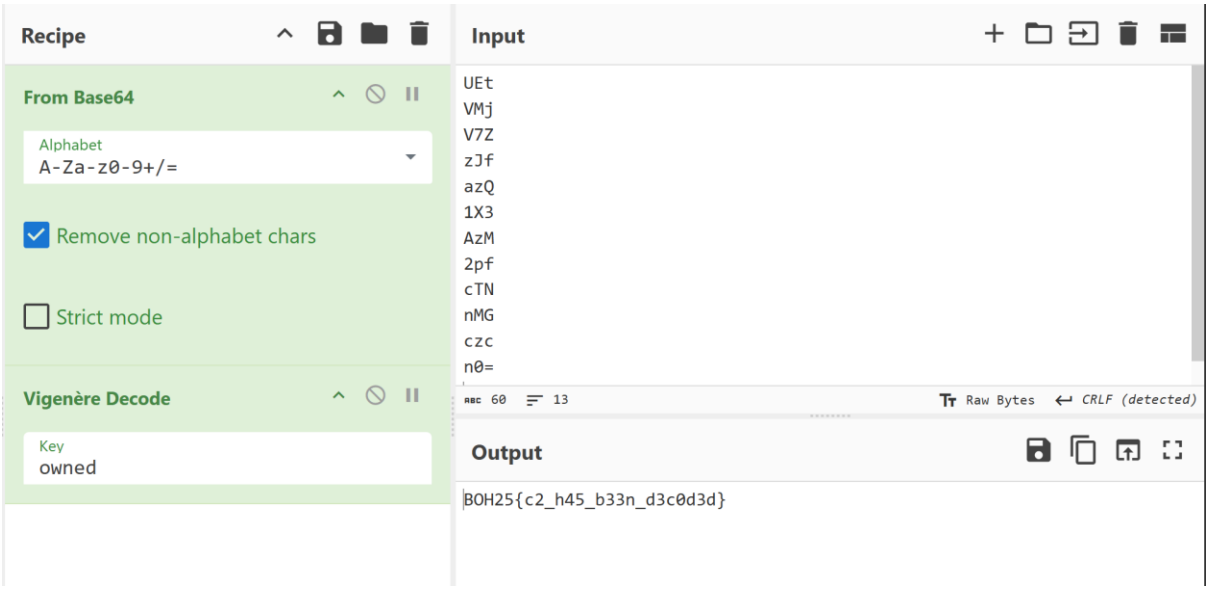


I then opened CapturedTraffic.pcap with wireshark and look for DNS-QUERY.

```
┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ tshark -r CapturedTraffic.pcap \
  -Y 'dns && dns.qry.name contains "c2.malcorp.bizarre"' \
  -T fields -E separator=$'\t' \
  -e frame.number \
  -e frame.time_relative \
  -e ip.src \
  -e ip.dst \
  -e _ws.col.Protocol \
  -e frame.len \
  -e _ws.col.Info
11      6.376488000     10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'UEt'.c2.malcorp.bizarre
13      6.444131000     8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'UEt'.c2.malcorp.bizarre SOA a.r
oot-servers.net
197     13.208566000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'VMj'.c2.malcorp.bizarre
213     13.275503000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'VMj'.c2.malcorp.bizarre SOA a.r
oot-servers.net
2374    20.765353000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'V7Z'.c2.malcorp.bizarre
2387    20.851842000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'V7Z'.c2.malcorp.bizarre SOA a.r
oot-servers.net
4461    28.544514000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'zJf'.c2.malcorp.bizarre
4481    28.631884000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'zJf'.c2.malcorp.bizarre SOA a.r
oot-servers.net
4559    36.404494000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'azQ'.c2.malcorp.bizarre
4561    36.493122000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'azQ'.c2.malcorp.bizarre SOA a.r
oot-servers.net
5014    43.740553000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'1X3'.c2.malcorp.bizarre
5019    43.826940000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'1X3'.c2.malcorp.bizarre SOA a.r
oot-servers.net
5273    51.152493000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'AzM'.c2.malcorp.bizarre
5281    51.242909000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'AzM'.c2.malcorp.bizarre SOA a.r
oot-servers.net
6802    59.116926000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'2pf'.c2.malcorp.bizarre
6826    59.189944000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'2pf'.c2.malcorp.bizarre SOA a.r
oot-servers.net
7195    66.818629000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'cTN'.c2.malcorp.bizarre
7197    66.907279000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'cTN'.c2.malcorp.bizarre SOA a.r
oot-servers.net
7245    73.484555000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'nMG'.c2.malcorp.bizarre
7247    73.572700000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'nMG'.c2.malcorp.bizarre SOA a.r
oot-servers.net
7329    81.524497000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'czc'.c2.malcorp.bizarre
7331    81.612016000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'czc'.c2.malcorp.bizarre SOA a.r
oot-servers.net
9010    88.223493000    10.0.3.15       8.8.8.8 DNS     85      Standard query 0x0000 A b'n0='.c2.malcorp.bizarre
9015    88.315210000    8.8.8.8 10.0.3.15       DNS     160     Standard query response 0x0000 No such name A b'n0='.c2.malcorp.bizarre SOA a.r
oot-servers.net
```

```
┌──(kali㉿kali)-[~/Desktop/Bleeding]
└─$ tshark -r CapturedTraffic.pcap \
  -Y 'dns.flags.response == 0 && dns.qry.name contains "c2.malcorp.bizarre"' \
  -T fields -e dns.qry.name \
| grep -oP "b'\K[^']+(?='\.c2\.malcorp\.bizarre)"
UEt
VMj
V7Z
zJf
azQ
1X3
AzM
2pf
cTN
nMG
czc
n0=
```

For better visualization, I used a command to list down all the DNS Query record and I noticed each record has some weird strings on it which is most likely to be the stolen data.



Since I already knew the encoding algorithm was Vigenère Encode first then Base64 Encode. Therefore, I needed to reverse the encryption by decrypting from Base 64 first then Vigenère Decode with the key “owned”.

Flag: BOH25{c2_h45_b33n_d3c0d3d}